

Information Security Policy

Application: Personal Budget Application (Coffer) | **Owner:** Randall Miller (randallsm83@gmail.com) | **Version:** 1.0 | **Effective Date:** March 18, 2026 | **Review Cycle:** Annually

1. PURPOSE AND SCOPE

This Information Security Policy (ISP) establishes the security objectives, responsibilities, and controls for the Personal Budget Application ("Coffer," "the Application"). It applies to all systems, data, and infrastructure used to operate the Application, including cloud hosting, database services, third-party integrations (Plaid), and developer workstations. The policy is reviewed annually and updated upon material changes to the Application's architecture or threat landscape.

2. SECURITY OBJECTIVES

- **Confidentiality:** Protect consumer financial data from unauthorized access or disclosure.
- **Integrity:** Ensure that data stored and processed by the Application is accurate and unaltered.
- **Availability:** Maintain Application availability appropriate for a personal finance use case.

3. ACCESS CONTROL

Access to all systems is governed by the Application's Access Control Policy. Key controls include:

- All user-facing access requires authentication (email + password, minimum 8 characters).
- Multi-factor authentication (TOTP) is available and encouraged for all users.
- Administrative access to hosting (Vercel), database (Neon), and source code (GitHub) is restricted to the application owner and protected by MFA.
- All database queries are scoped to the authenticated user's ID, preventing cross-user data access.
- Secrets and credentials are stored as environment variables and never committed to source control.

4. DATA PROTECTION

- All data in transit is encrypted using TLS 1.2 or higher.
- All data at rest is encrypted by the underlying database provider (Neon PostgreSQL).
- Plaid access tokens are encrypted at rest using AES-256-GCM with a dedicated encryption key.
- User passwords are hashed using bcrypt (cost factor 10+) and never stored in plaintext.
- Consumer financial data is not shared with any third party except Plaid, which retrieves the data on the user's behalf.

5. VULNERABILITY AND PATCH MANAGEMENT

- Application dependencies are monitored for known vulnerabilities using GitHub Dependabot and `npm audit`.
- Critical vulnerabilities (CVSS ≥ 9.0) are remediated within 7 days of identification.
- High vulnerabilities (CVSS 7.0–8.9) are remediated within 30 days of identification.
- Runtime environments (Node.js, etc.) are managed via `mise` and kept on current supported LTS versions.
- End-of-life software and dependencies are identified during periodic reviews and updated or replaced.

6. INCIDENT RESPONSE

In the event of a suspected security incident (unauthorized access, data breach, or credential compromise):

- Affected credentials and API keys are rotated immediately.
- Plaid access tokens for affected users are revoked via the Plaid API.
- Affected users are notified within 72 hours of confirmed breach discovery.
- Incident details are documented and the root cause addressed before restoring normal operations.

7. SECURE DEVELOPMENT

- All code changes are reviewed before deployment.
- Secrets are managed via environment variables; no credentials are committed to source control.
- Third-party dependencies are evaluated for security before adoption.

- Server-side validation is applied to all user inputs.
- API routes verify authenticated session on every request.

8. PHYSICAL AND LOGICAL SECURITY

- Production infrastructure is hosted entirely in cloud environments (Vercel, Neon) with provider-managed physical security.
- Developer workstations use full-disk encryption and are protected by OS-level authentication.
- SSH keys used for repository access are managed by 1Password SSH agent and protected by biometric/passkey authentication.

9. COMPLIANCE AND REVIEW

This policy is designed to support compliance with applicable privacy and financial data regulations, including CCPA and GLBA provisions relevant to personal financial data. The policy is reviewed and updated annually, or upon material changes to the Application, its infrastructure, or applicable law.

Next scheduled review: March 2027

Acknowledged and approved by:

Randall Miller

Signature

Randall Miller

Printed Name

March 18, 2026

Date